Министерство науки и высшего образования Российской Федерации
Федеральное государственное автономное образовательное учреждение высшего образования
«Московский государственный технический университет имени Н.Э. Баумана (национальный исследовательский университет)»
(МГТУ им. Н.Э. Баумана)

ФАКУЛЬТЕТ **ИНФОРМАТИКА И СИСТЕМЫ УПРАВЛЕНИЯ**

КАФЕДРА **КОМПЬЮТЕРНЫЕ СИСТЕМЫ И СЕТИ (ИУ6)**

НАПРАВЛЕНИЕ ПОДГОТОВКИ **09.03.01 Информатика и вычислительная техника**

Отчет
по домашнему заданию

по дисциплине «Защита информации»

Тема: «Защита информации интернет-магазина»

Студент группы ИУ6-83Б _____ Р.В. Дорохов
(Подпись, дата) (И.О. Фамилия)

Преподаватель _____ Д.А. Миков
(Подпись, дата) (И.О. Фамилия)

2026 г.

Источники информации и способы доступа

Интернет-магазин как автоматизированная система одновременно является публичным веб-сервисом, обрабатывающим персональные данные клиентов, и элементом платёжного контура, где критична защита платёжных реквизитов, устойчивость к мошенничеству и доступность 24/7.

Типовой интернет-магазин - это совокупность публичных и внутренних компонентов: веб-витрина и/или мобильное приложение, backend (каталог, цены/акции, корзина, оформление заказа, управление доставкой, личный кабинет), API для партнёров и интеграций, административная панель, контуры хранения (БД, поисковый индекс, кэш, очереди), а также внешние сервисы (платёжная система, доставка, email/SMS-рассылки, аналитика). Именно информационные процессы (сбор - передача - хранение - обработка - выдача/удаление) определяют, какие свойства являются критическими и где проходят границы доверия.

Источники информации в интернет-магазине обычно включают:

1. данные клиента (ФИО, телефон, email, адрес доставки, история заказов);
2. данные учётной записи (логины, хэши паролей, токены сессий);
3. данные заказа (состав корзины, стоимость, скидки, статусы, возвраты);
4. операционные данные (склад/остатки);
5. журналы событий (логи приложений/доступов);
6. телеметрию безопасности

Способы доступа к данным и функциям системы делятся на: публичный доступ (браузер/мобильное приложение), программный доступ (API партнёров, интеграции с доставкой), и привилегированный доступ (админ-панель, доступ DevOps к инфраструктуре, доступ службы поддержки к данным клиентов). Практика смещения защиты к пользователям, активам и ресурсам вместо опоры на статический сетевой периметр характерна для модели Zero Trust. В этом подходе доверие не предоставляется автоматически на основании нахождения внутри корпоративной сети - каждая попытка доступа к системе, сервису или данным проверяется отдельно. Контроль осуществляется на уровне идентификации пользователя, его роли, устройства, контекста запроса и конкретного ресурса. Для привилегированных контуров интернет-магазина (например, админ-панели, платёжной инфраструктуры, системы управления заказами или складом) это особенно важно, поскольку компрометация даже одного аккаунта или сервиса может привести к финансовым потерям, утечке данных клиентов или остановке бизнеса. Поэтому доступ к таким контурам должен быть минимально необходимым и постоянно верифицируемым, а не основанным на принципе «внутри сети - значит доверенный».

Платёжный процесс - это зона повышенного риска, поскольку связан с обработкой финансовых данных клиентов. Поэтому к нему применяются более строгие меры защиты: изоляция (логическое и сетевое разделение), ограничение доступа (минимально необходимые права), журналирование (запись событий и действий) и контроль изменений (формализованное управление изменениями). Если магазин полностью передаёт ввод и обработку данных карт платёжному провайдеру (через редирект или размещённую платёжную страницу), его собственный платёжный контур уменьшается - данные карт не проходят через инфраструктуру магазина. Это снижает риски и зону ответственности, но всё равно требует правильно определить границы контура и изолировать системы, которые участвуют в процессе оплаты, от остальной инфраструктуры.

Виды угроз, источники угроз и объекты угрозы

Источники угроз обычно делят на внешние, внутренние и связанные с цепочкой поставок. К внешним относятся киберпреступники, мошенники и автоматизированные боты, действующие из интернета. Их целью может быть кража денег, персональных данных или нарушение работы магазина. Внутренние угрозы связаны с действиями сотрудников: это могут быть случайные ошибки в настройках доступа или преднамеренные злоупотребления. Отдельную категорию составляет цепочка поставок - сторонние библиотеки, подрядчики, облачные сервисы и системы автоматической сборки и публикации кода. Если один из этих элементов оказывается скомпрометирован, атака может попасть в инфраструктуру магазина через доверенный канал.

В интернет-магазине можно выделить несколько основных **видов угроз**. Прежде всего это угрозы конфиденциальности - кража персональных данных клиентов, учётных записей и платёжной информации.

Второй тип - угрозы целостности, когда злоумышленник изменяет данные: цены товаров, реквизиты для оплаты, статусы заказов или условия скидок.

Третья категория - угрозы доступности, направленные на вывод сайта из строя, например через перегрузку сервера запросами (DDoS-атаки).

Объектами атак в интернет-магазине чаще всего становятся публичные веб-страницы и формы - поиск, вход в личный кабинет, оформление заказа. Также высокий интерес представляют административные панели, через которые сотрудники управляют заказами и товарами, базы данных с информацией о клиентах и покупках, система управления ценами и скидками, а также подсистема возвратов. Не менее важны файловые хранилища и процессы сборки и доставки обновлений, поскольку через них возможно внедрение вредоносного кода.

Особенностью современных интернет-магазинов является широкое использование API - программных интерфейсов, через которые сайт и мобильное приложение взаимодействуют с сервером. Это делает архитектуру более гибкой, но одновременно расширяет поверхность атаки: злоумышленник может направлять запросы напрямую к серверной логике, минуя привычный пользовательский интерфейс.

Значительную долю инцидентов составляют автоматизированные атаки. Боты массово перебирают логины и пароли, используя ранее утёкшие базы данных (этот метод называют credential stuffing), проверяют уязвимости, перебирают купоны и промокоды или автоматически копируют каталог и цены. Такие действия могут приводить к финансовым потерям и создавать серьёзную нагрузку на систему.

Одним из ключевых сценариев для интернет-магазина является кража учётных данных - логинов, паролей, токенов и ключей доступа. Получив такие данные, злоумышленник может действовать от имени реального пользователя. Это может привести к захвату аккаунта клиента, компрометации административных учётных записей и последующему доступу к управлению системой. Именно поэтому защита механизмов аутентификации и контроля доступа является одним из центральных направлений обеспечения безопасности интернет-магазина.

Направления, средства и способы защиты

В интернет-магазине **направления защиты** формируются исходя из ключевых рисков: защиты персональных данных клиентов, предотвращения финансового мошенничества, обеспечения доступности сервиса и сохранности бизнес-логики (цены, скидки, заказы). В первую очередь необходимо защищать механизмы аутентификации и авторизации, поскольку компрометация учётных данных часто становится отправной точкой атаки. Второе важное направление - сегментация инфраструктуры: разделение публичной части, административного контура и внутренних сервисов. Также критичны защита платёжного процесса, контроль целостности кода и зависимостей, а также мониторинг и оперативное реагирование на инциденты. Отдельным направлением выступает защита от автоматизированных атак и злоупотреблений бизнес-логикой.

Средства защиты - это конкретные технические и организационные инструменты, которые используются для снижения рисков. К ним относятся межсетевые экраны (firewall) для фильтрации трафика, WAF (Web Application Firewall) для защиты веб-приложений от типовых атак, системы обнаружения вторжений, антибот-решения, механизмы многофакторной аутентификации и строгой политики паролей. Для защиты данных применяются шифрование при передаче и хранении, резервное копирование и контроль доступа по принципу минимальных привилегий. Важную роль играют системы журналирования и мониторинга, позволяющие фиксировать события и выявлять подозрительную активность. На уровне разработки используются проверка кода, сканирование уязвимостей и контроль сторонних компонентов.

Способы защиты - это практические подходы к применению средств безопасности. К ним относится принцип «минимально необходимых прав», при котором пользователь или сервис получает только тот доступ, который ему действительно нужен. Применяется сегментация сети - разделение

инфраструктуры на изолированные зоны. Используется регулярное обновление программного обеспечения для устранения известных уязвимостей. Вводится обязательная проверка изменений перед публикацией кода и разграничение полномочий сотрудников. Для борьбы с автоматизированными атаками внедряются ограничения частоты запросов, CAPTCHA и анализ поведенческих аномалий. В совокупности эти меры позволяют не только предотвратить атаки, но и быстро обнаружить их на ранней стадии и минимизировать последствия.

Практические методы обеспечения безопасности

Рационально строить защиту интернет-магазина как defense-in-depth, но привязывать её к управляемой модели. Практичный «каркас» - NIST CSF 2.0 (концепция кибербезопасности, разработанная институтом стандартов и технологий США): функции GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER формируют полную цепочку управления риском, где GOVERN задаёт стратегию, ожидания и политику, а остальные функции «приземляют» это в процессы и меры.

- GOVERN (управление): формализовать зоны ответственности, правила работы с персональными и платёжными данными, и требования к поставщикам/подрядчикам. GOVERN - это установление, доведение и мониторинг стратегии/ожиданий/политик управления риском.
- IDENTIFY (идентификация): инвентаризация активов и потоков данных (включая сторонние скрипты фронтенда и библиотеки), классификация данных. Для разработки полезно опираться на практики NIST SP 800-53 как каталог контролей безопасности и приватности, применимых к системам и организациям.
- PROTECT (защита): идентификация и аутентификация: обязательная многофакторная аутентификация для админов и всех привилегированных ролей, защита от фишинга, управление жизненным циклом аутентификаторов, ограничение времени жизни токенов, использование шифрования TLS 1.3 как

современного базового протокола, запрет небезопасных протоколов, защита фронтенда от скимминга/инъекций скриптов.

- DETECT (обнаружение): полноценные security-логи (аутентификация, контроль доступа, платежные действия, изменения цен/скидок, возвраты, административные операции), корреляция и алертинг.
- RESPOND (реагирование): формально заранее определить реакцию на киберугрозу - кто принимает решения, как изолируется контур, как собираются артефакты, как взаимодействовать с платёжным провайдером/хостингом/юристами/маркетологами.
- RECOVER (восстановление): резервирование, приоритеты восстановления (заказы/оплата/каталог/личный кабинет), регулярные учения и тест восстановления.

Критический слой - безопасная разработка и поставка ПО. Для цепочки поставок ПО особенно полезны:

- SBOM (Software Bill of Materials) как формальный перечень компонентов и связей поставок. Это как «паспорт» для программного обеспечения. Он содержит формальный список всех компонентов, из которых состоит программа: библиотеки, модули, зависимости, их версии и откуда они пришли. SBOM помогает понять, из чего состоит ПО, и быстро реагировать на уязвимости: если появляется баг или уязвимость в одной из библиотек, можно быстро определить, какие продукты этим компонентом затронуты. Также он важен для управления лицензиями и соблюдения требований безопасности поставок.
- Фреймворк SLSA нужен для контроля целостности процесса сборки программного обеспечения и его артефактов (например, исполняемых файлов или пакетов). SLSA описывает уровни безопасности (от базового до строгого) и треки, которые показывают, как именно построена цепочка поставок. С помощью SLSA компании могут системно уменьшать риск, что кто-то подменит или взломает ПО на этапе сборки.

- OWASP SCVS как практический стандарт оценки и улучшения assurance цепочки поставок компонентов. Это практический стандарт для оценки и повышения уверенности в безопасности цепочек поставок ПО. Он помогает организациям проверять, что компоненты, которые они используют, безопасны и что их поставки надежны. SCVS дает конкретные шаги: как проверять библиотеки, как строить отчёты, какие процессы внедрять, чтобы снизить риск использования вредоносного или подменённого кода.

На прикладном уровне «инструментальный слой» обычно строится вокруг следующих групп:

- IAM/PAM (управление доступом) для привилегированных учетных записей и строгого разделения ролей. Это системы, которые контролируют, кто и с какими правами может работать с системой. PAM (Privileged Access Management) особенно следит за «привилегированными» аккаунтами - теми, кто может менять настройки, данные или управлять серверами. Основная цель - строгая сегрегация ролей, чтобы один человек не мог сделать всё сразу и случайно или намеренно навредить системе.

- WAF/API-gateway и антибот-контроли против автоматизированных атак. WAF (Web Application Firewall) и API-шлюзы защищают веб-приложения и API от вредоносного трафика и атак. Антибот-механизмы блокируют автоматизированные попытки взлома, сканирования или спама. Вместе они снижают риск, что злоумышленник получит доступ через интернет-сервисы.

- Сканирование уязвимостей и тестирование как часть жизненного цикла разработки ПО.

- Секрет-менеджмент и предотвращение утечек ключей. Это системы для безопасного хранения паролей, API-ключей, токенов и других чувствительных

данных. Они предотвращают случайное раскрытие секретов, например, в коде или логах.

- Резервирование и изоляция бэкапов с регулярными проверками восстановления.

Практические методы обеспечения безопасности интернет-магазина строятся на принципе многоуровневой защиты (defense-in-depth), но при этом должны быть интегрированы в управляемую модель киберрисков. Такой подход позволяет не просто внедрять отдельные технологии, а формировать согласованную систему: от стратегического управления (GOVERN) и идентификации активов (IDENTIFY) до защиты (PROTECT), мониторинга (DETECT), реагирования (RESPOND) и восстановления (RECOVER).

Особое внимание стоит уделять безопасной разработке и цепочке поставок ПО, где SBOM, SLSA и OWASP SCVS обеспечивают прозрачность компонентов и контроль целостности сборки. На операционном уровне критически важны инструменты управления доступом, защитные шлюзы, сканирование уязвимостей, секрет-менеджмент и надежные резервные копии.

В итоге, комбинируя управленческий, инженерный и операционный подходы, организация получает систему, способную минимизировать риски, быстро выявлять и локализовать инциденты, а также восстанавливаться после сбоев. Такой подход не только повышает безопасность, но и укрепляет доверие клиентов, партнеров и регуляторов к интернет-магазину.

Заключение

Информационная безопасность интернет-магазина представляет собой комплексную задачу, включающую защиту персональных данных клиентов, обеспечение целостности и доступности сервисов, а также устойчивость к финансовому мошенничеству и автоматизированным атакам. Эффективная защита требует интеграции нескольких уровней: стратегического управления рисками, инженерных решений и операционных мер.

Использование управляемой модели, например NIST CSF 2.0, позволяет системно связывать цели бизнеса и требования безопасности с конкретными процессами и инструментами: от GOVERN и IDENTIFY до PROTECT, DETECT, RESPOND и RECOVER. На уровне разработки и поставки ПО критически важны SBOM, SLSA и OWASP SCVS, которые обеспечивают прозрачность компонентов, контроль целостности и снижение рисков при работе с внешними библиотеками и поставщиками.

На операционном уровне ключевыми являются управление доступом (IAM/PAM), защитные шлюзы и WAF, антибот-контроли, сканирование уязвимостей, секрет-менеджмент и резервирование данных. Совокупное применение этих мер формирует многоуровневую систему защиты (defense-in-depth), позволяющую своевременно обнаруживать угрозы, минимизировать последствия инцидентов и обеспечивать восстановление критически важных сервисов.

Таким образом, современный интернет-магазин становится не просто набором технических компонентов, а устойчивой и управляемой системой, где безопасность встроена на всех уровнях. Это повышает доверие клиентов и партнеров, снижает операционные и финансовые риски и обеспечивает стабильность бизнеса в условиях постоянно меняющейся киберугрозы.